

[Retour à mon espace](#)

RM

Créez une API sécurisée RESTful en utilisant Django REST

CONTENU

- Mission
- Livrables et soutena...
- Évaluation

SUPPORTS PÉDAGOGIQUES

- Compan... **Nouveau**
- Guide mentor**
- Cours
- Ressources

Guide mentor



Si votre étudiant a commencé ce projet avant le 28/06/2023, il a débuté son travail sur **ce projet archivé**. Il peut continuer l'existant ou recommencer avec ce nouveau projet, dont les modifications s'alignent avec les retours étudiants. Vous pouvez télécharger l'ancien **guide mentor ici**.

Avant de commencer les sessions de mentorat sur ce projet, veuillez à lire la mission du projet et les étapes clés associées.

Vous y trouverez notamment des recommandations qui pourront vous aider dans votre accompagnement.

Note d'accompagnement



[Retour à mon espace](#)

RM

Créez une API sécurisée RESTful en utilisant Django REST

CONTENU

-  Mission
-  Livrables et soutena...
-  Évaluation

SUPPORTS PÉDAGOGIQUES

-  Compan... **Nouveau**
-  **Guide mentor**
-  Cours
-  Ressources

Le projet peut présenter quelques difficultés lorsqu'il s'agit de respecter les **normes OWASP et RGPD** et d'ajouter des règles d'autorisation pour différents types d'utilisateurs et leurs groupes (contributeurs). Vous pouvez conseiller à l'étudiant de commencer par analyser le diagramme de classe et identifier les modèles d'objets, comme décrit dans le document de conception de la mise en œuvre.

Une fois qu'il aura bien compris ce qui doit être développé et pourquoi, demandez-lui de configurer son projet. Pour cela, il devra suivre les instructions fournies par la [documentation officielle de Django REST](#).

La fonctionnalité de connexion et d'inscription doit être mise en œuvre à l'aide de **JWT** afin d'adhérer aux règles d'authentification de l'OWASP et du RGPD. L'intérêt du JWT est d'**éviter la sauvegarde des sessions utilisateur** et d'entrer dans une logique dite « **Stateless** » (sans état), ceci afin de créer des requêtes compréhensibles et indépendantes.

Il pourra être intéressant de revenir sur ce concept avec l'étudiant en mettant en relation le JWT avec l'authentification par sessions/cookies. OAuth2, une norme de connexion, peut aussi être abordée, notamment pour comprendre comment se connecter avec un compte Google.

Il peut tester ses points de terminaison d'API avec **Postman**.



Créez une API sécurisée RESTful en utilisant Django REST

CONTENU

-  Mission
-  Livrables et soutena...
-  Évaluation

SUPPORTS PÉDAGOGIQUES

-  Compan... **Nouveau**
-  **Guide mentor**
-  Cours
-  Ressources

vers une utilisation optimisée et intelligente de l'application, en évitant la multiplication de requêtes inutiles. Aidez-vous des principes **DRY** (Don't Repeat Yourself), **KISS** (Keep It Simple and Sparkling) et **YAGNI** (You Aren't Gonna Need It) pour ce procédé. Il est inutile de pousser l'étudiant sur une optimisation brute de l'API. Il s'agira plutôt d'éviter les pièges de conception évidents (requêtes anormalement lentes, imbrications de données inutiles...) et de **sensibiliser l'étudiant à l'impact qu'aura la consommation des données sur le serveur** et, par extension, l'environnement. Les concepts de mise en cache pourront être abordés à l'oral par exemple. Les wireframes et spécifications clients peuvent être abordés pour insister sur **l'apport d'une bonne documentation client**, afin de mieux connaître le besoin et **simplifier** les requêtes pour ne retourner que ce dont l'utilisateur a besoin.

Pensez à lui rappeler les ressources et les liens fournis dans les documents en pièces jointes et dans l'onglet des ressources pour réaliser ses tâches.

Après que votre étudiant a terminé ce projet, rappelez-lui de mettre à jour son portfolio GitHub et sa veille professionnelle et technique. Il peut ajouter du code au portfolio et des ressources ou des outils à la veille. S'il n'a pas encore démarré son portfolio ou sa veille, encouragez-le à profiter de l'occasion pour les démarrer. Il peut se référer au projet [Préparez-vous pour l'après-formation](#) mis à jour.

Tableau de correspondance

[Retour à mon espace](#)

RM

Créez une API sécurisée RESTful en utilisant Django REST

CONTENU

- Mission
- Livrables et soutena...
- Évaluation

SUPPORTS PÉDAGOGIQUES

- Compan... **Nouveau**
- Guide mentor**
- Cours
- Ressources

Securiser une API afin qu'elle respecte les normes OWASP et RGPD • Le repository GitHu

Critères d'évaluation

Créer une API RESTful avec Django REST

L'API est **terminée** lorsque les conditions suivantes sont remplies :

- ☐ Tous les modèles identifiés dans le diagramme des relations de système sont présents ;
- ☐ L'API :
 - renvoie une réponse JSON appropriée pour chaque point de terminaison,
 - utilise des sérialiseurs pour les opérations de lecture et d'écriture,
 - est pleinement fonctionnelle et répond à chaque besoin énoncé
- ☐ Les modèles sont correctement liés les uns aux autres, pour permettre toutes les fonctionnalités définies dans le document de conception ;
- ☐ Tous les attributs et paramètres de la requête sont définis pour assurer les fonctionnalités mentionnées dans le document de conception ;
- ☐ Le projet est bien structuré, avec tous les modèles, sérialiseurs, vues et routes placés dans leur module respectif pour l'application. Les modules ne sont pas placés de façon aléatoire



Créez une API sécurisée RESTful en utilisant Django REST

CONTENU

- Mission
- Livrables et soutena...
- Évaluation

SUPPORTS PÉDAGOGIQUES

- Compan... **Nouveau**
- Guide mentor**
- Cours
- Ressources

Sécuriser une API afin qu'elle respecte les normes OWASP et [RGPD](#)

L'API est **sécurisée** lorsque les conditions suivantes sont remplies :

- ☐ **L'authentification utilise le JWT** (JSON Web Token) : Ce type d'authentification limite la propagation des comptes hackés car chaque token possède une durée de vie limitée ;
- ☐ **Les vérifications d'authentification sont intégrées** : L'authentification est demandée à chaque point de terminaison (hors inscription) en en-tête de requête ;
- ☐ **L'accès est défini par un système de permissions** : Seul l'auteur d'une ressource peut la modifier ou la supprimer ;
- ☐ La gestion et la mise à jour des dépendances sont assurées à l'aide d'un outil comme Pipenv ou Poetry ;
- ☐ Toute donnée créée par un utilisateur est accessible et modifiable par ce dernier. L'utilisateur a le droit à l'oubli (possibilité de suppression réelle de la donnée) ;
- ☐ L'inscription définit des règles de consentement (compactable, partageable, etc.), récolte et vérifie l'âge de l'utilisateur ;
- ☐ L'étudiant est capable d'expliquer les mesures de sécurité mises en place et en quoi elles respectent l'OWASP et le RGPD.

L'API est **« green »** si les conditions suivantes sont remplies :



Créez une API sécurisée RESTful en utilisant Django REST

CONTENU

-  Mission
-  Livrables et soutena...
-  Évaluation

SUPPORTS PÉDAGOGIQUES

-  Compan... **Nouveau**
-  **Guide mentor**
-  Cours
-  Ressources

inférieur à 200 ms) ;

- ☐ Les points de terminaison ne retournent pas de donnée superflue (attention à l'imbrication des ressources, qui est particulièrement consommatrice) ;
- ☐ Le listage des ressources est bridé par l'implémentation d'une pagination ;
- ☐ L'étudiant est capable d'expliquer ce qu'il a mis en place pour rendre son code green.

Soutenance

Pour la structure de la soutenance, référez-vous à la section Livrables et soutenance.

Pour faciliter votre travail, voici à nouveau les critères d'évaluation que vous devez vérifier pendant la soutenance :

- ☐ L'étudiant est capable d'expliquer les mesures de sécurité mises en place et en quoi elles respectent l'OWASP et le RGPD ;
- ☐ L'étudiant est capable d'expliquer ce qui rend son code green, et pourquoi la mise en place d'une pagination permet de tendre vers ce concept.

[Retour à mon espace](#)

RM

Créez une API sécurisée RESTful en utilisant Django REST

CONTENU

-  Mission
-  Livrables et soutena...
-  Évaluation

SUPPORTS PÉDAGOGIQUES

-  Compan... **Nouveau**
-  **Guide mentor**
-  Cours
-  Ressources

code en direct.

Cela vous permettra d'observer ses réflexes, sa logique et sa capacité à résoudre des problèmes en temps réel.

Par ailleurs, prenez le temps d'examiner le nombre et la nature des commits qu'il a effectués dans son projet. Les commits offrent une trace des étapes de son travail, reflétant son implication, son processus de réflexion, ainsi que sa manière de corriger et d'améliorer son code.

Ces éléments combinés vous fourniront une évaluation concrète et précise de son niveau de maîtrise et de compréhension.

Une soutenance mérite un refus dans les cas suivants :

- Critères d'évaluation non validés pour une ou plusieurs compétences ;
- Plagiat (veillez à poser des questions méthodologiques ou sur le raisonnement de la solution pour vous assurer que le travail a bien été réalisé par l'étudiant) ;
- Une présentation en dessous de 10 minutes ou au-dessus de 20 minutes. Néanmoins, une tolérance de +/- 20 % est permise, selon les cas.

[Retour à mon espace](#)

RM

Créez une API sécurisée RESTful en utilisant Django REST

CONTENU

-  Mission
-  Livrables et soutena...
-  Évaluation

SUPPORTS PÉDAGOGIQUES

-  Compan... **Nouveau**
-  **Guide mentor**
-  Cours
-  Ressources